

风险

人员风险

- 雇佣
 - 1.建立job/position description
 - 2.设立job classification
 - 3.人员筛选 — 背景调查: 技能、药物、信用、驾驶记录、性格、社交网络帐号(发布不当内容-获法务同意)
 - 4.入职+培训 — 雇佣协议 + 可接受使用策略AUP + 保密协议NDA + 竞业禁止协议NCA(不可跳槽)
- 解雇
 - 离职面谈: 旨在依据协议审查责任和约束条件 — 可选: 再次签署NDA
 - 通知时 禁止系统访问权限
 - 安保人员陪同

供应链风险管理

SCRM

- 背景: IT硬件多由不同厂家的产品组成 《供应链难管控》
 - *供应商管理系统VMS: 订购、合并计费等等 + 合同/交易保密、活动日志
 - *多方风险: 当项目涉及多个组织
- 生命周期: Vendor Selection - Onboarding - Monitoring - Offboarding
- 书面协议
 - 保密协议NDA: 含客户信息保密要求
 - ! 第一签 单向/双向
 - 基础合同UC: 主合同 — 主服务协议MSA: 合作关系的主要条款 overall & ongoing — 工作说明书SOW: 每个项目的具体要求 limited & specific per project
 - underpinning contract 当公司和供应商有多个项目时 Statement of Work
 - 服务级别协议SLA: SLR + 处罚 + 服务失效时的补救措施 — 服务水平需求SLR: 响应时间、可用性、数据保存...
 - 其它
 - 合作伙伴协议BPA: 指定各方的责任和分红 当不同公司合作时
 - 互连安全协议ISA: 细化技术和安全需求, 如拓扑图、加密要求 当不同公司互连网络时
 - 谅解/协议备忘录MOU/MOA: 非正式、无处罚条款/需求细节、有背景+双方责任(汇报/安全/时间) — 运营级别协议OLA 常用于同一家公司 不同部门间
- 标准
 - ISO/IEC 27036 供应商关系安全管理 4 parts: 2016-2023
 - NISTIR 8276 Key practice in cyber supply chain risk mgnt: observation from industry NIST技术报告
 - NIST 800-161 网络安全供应链风险管理实践 for systems and organizations
 - ENISA Supply Chain Integrity刊物: 风险和挑战
- 产品支持
 - EO Life: 制造商停止制造/售卖产品
 - EO Support / EO Service Life: 制造商停止技术支持与更新
 - 防: 关注产品公告 - 提前准备 — EOL政策: 制造商指导客户如何产品过渡的指南
- 开源软件
 - 检查组件 by 软件组件分析SCA/包管理工具
 - 是否篡改 by 下载后验证GPG/PGP签名

【威胁代理】【攻击】【资产】的【脆弱性】导致【暴露】就是【风险】通过【防护措施】预防, 否则被【破坏】

- 暴露: 最坏的情况是什么
- 威胁代理 Agent/Actors: 黑客/坏人
- 威胁事件 Events: 火灾、地震、人为错误...
- 威胁路径/攻击向量 Vector: =攻击手段, 如邮件、WiFi、网站...
- 风险: 外部/内部、多方(影响多家企业)、过时系统、知识产权、软件许可

- 1.风险识别
 - 编制资产清单 - 分配AV — 估值 by
 - 成本法: 更换资产的成本 / 原购入成本 / 折旧成本
 - 收入法: 预期收入*资本化率、资本化率=实际收入/资产价值 — 1w的威胁情报去年带来1k收入、预测今年2k= 2k*(1k+1w)
 - 市场法: 类似资产的费用(透明前提)
 - 识别每个资产面临的威胁 - 编制“资产-威胁配对表” — 场景: 对单个威胁的书面描述(1页), 含如何产生、可能影响
- 2.风险评估/分析
 - 定性分析 — 头脑风暴、自由讨论、Delphi、故事板、焦点组、调查问卷、核对清单、面谈 — 参会人员: 数量+多样性
 - 计算 每个资产-威胁的 暴露因子EF (%) — = 单个资产的潜在损失百分比 — 如: DoS致服务器降能70% EF=70%
 - 计算 单一损失期望SLE — $SLE=EF*AV$ — = 单个资产发生单个威胁的成本损失
 - 计算 年发生量ARO (非%) — = 单个威胁发生的概率X引起威胁的用户数量 — 如: 每人每月出错一次+共100人 ARO=1*12*100
 - 定量分析
 - 计算 年度损失期望ALE — $ALE=ARO*SLE$
 - +辅助软件
 - 制定对策 - 重新计算ARO、ER、ALE
 - 对策的成本/效益分析
 - 对策年度成本ACS: 包括购置、测试、实施、运营、修理、升级、环境改变
 - 对策价值 = 对策前ALE - 对策后ALE - ACS, +考虑法律后果
 - 对策排序 by 对策价值大>小 + 预算 + 兼容性 + 人员技能 + 政治...

企业风险管理

ERM

- 类型
 - 风险缓解/降低: by 控制 Mitigation / reduction
 - 风险规避: 消除发生原因、选择替代项 Avoidance
 - 风险转移: 如保险、外包 Transference / Assignm...
 - 注: 云外包无法转移风险至CSP
 - Cyber risk insurance: to cover costs of
 - forensic investigation, 如第三方调查员
 - direct biz losses, 如金钱、员工加班、声誉 — recovery costs, 如替换硬件、临时云部署
 - legal notification, 告知数据/隐私泄露 — lawsuits, 诉讼支出 — extortion, 勒索赎金
 - food and logistic expense, 如员工出差补贴
 - 风险接受: 成本/效益 — 需书面签字说明 Acceptance
- 3.风险响应
 - 风险决策 by
 - 固有/初始风险 — 总风险 = 威胁*脆弱性*AV Inherent / ini...
 - 残余风险 = 总风险 - 控制间隙 = 决定接受的风险 Residual
 - 风险偏好: 组织愿意承担的风险总量 Appetite
 - 风险容忍度: 组织对每个资产-威胁的愿意承担的风险量 Tolerance
 - 风险能力: 组织实际能够承担的风险总量 capacity
 - 控制风险: 因引入控制 而造成的新风险 / 对财报的CIA有潜在影响的风险 Control
 - 输出
 - 风险报告
 - 风险登记册: 含风险描述、分类、可能性*影响、等级、响应步骤(已完成+未完成) — Risk Profile: 梳理组织面临的风险 Risk category: minimal, low, moderate, high, critical
- 4.持续改进 — 风险成熟度模型RMM: 评估ERM水平 by 70+指标 付费 by RIMS
 - 1 Ad hoc: 起点
 - 2 Initial: 各部门单独执行风险评估
 - 3 Repeatable: 组织统一风险框架
 - 4 Managed: 风险管理集成至业务流程 + 指标收集
 - 5 Leadership: 不仅被动防御 + 主动战略规划
- 5.监控 — 关键风险指标KRI
 - ISACA推荐标准: 业务影响、实施成本、可靠性、灵敏度
 - 如
 - 遗留漏洞的数量、漏洞解决时间、被盗账户数量、软件缺陷数、重复审计发现、恶意尝试intrusion attempts
 - Patching level 补丁完的设备数量、Time to deploy patches
 - 事件响应时间: MTTD发现、MTTC控制、MTTR解决 Mean Time To Detect Contain Resolve

ISO/IEC 31000 风险管理指南

2018

- 制定框架 by
 - “原则轮”: 创造与保护价值 + 八项原则
 - “框架轮”: 领导力与承诺 + 五个步骤(整合-设计-实施-评价-改进)
 - “过程轮”: 风险识别-分析-评价-应对-沟通咨询-监控评价-记录报告
- 31004: 实施指南
- 31010: 风险评估技术

风险框架

NIST SP 800-37 风险管理框架RMF

联邦/DoD+企业 r2 2018

- 1) 准备: 收集信息
 - 技术架构: 架构参考模型、技术细节、业务流程、系统边界
 - 组织特定信息: 适用法规、战略、资源可用性、供应链
- 2) 分类: 基于影响分析、对系统信息进行分类
- 3) 选择: 确定安全控制 = 安全基线+/-控制
- 4) 实施 安全控制
- 5) 评估 安全控制是否正确实施 - 初步整改
- 实施RMF by
 - 目的: 使用系统前 获得官方批准 — 演化: 替代Certification & Accreditation
 - 流程: 提交安全包(安全计划+评估报告+整改计划)至管理层 - 管理层决定风险控制是否合理+接受剩余风险
 - 角色
 - 授权员AO: 开展安全评估 - 授予ATO
 - 批准机构AA、指定批准机构DAA
 - 安全控制评估员SCA: 政府机构/政府合同商 — *安全控制评估SCA 多与 安全测试和评估ST&E 结合开展
 - 推荐员RO
 - 6) 授权: 授权运营ATO
 - 资质
 - 重新申请: 当 5年到期/ 严重安全漏洞/ 重大变更/ AO自行决定
 - 类型
 - Authorization to Operate: 风险可控
 - Common Control Authorization: 控制A继承自控制B + 控制B已被授予ATO
 - Authorization to Use: 乙方提供服务且乙方风险可控 / 享受别人的ATO
 - Denial of Authorization: 风险不可控
 - *CTCPEC - 加拿大: C、I、A、可控性
- 7) 监控 安全控制 + 持续评估并整改 + 更新文档

劣: 缺少自动化工具

NIST SP 800-39 管理信息安全风险: 组织、任务和系统视图

2011 基于800-37

- 步骤: 框架 - 评估、响应、监控
- 风管级别: 1级-组织、2级-任务/业务流程、3级-系统

ISACA's Risk IT Framework: 通用框架 - 结合NIST与ISO

COSO 企业风险管理-整合框架ERM

2017

- 治理和文化: 风险监督、营运架构... 战略和目标设定: 风险偏好...
- 绩效: 风险识别、评估...
- 审查和修订: 评估实质变化...
- 信息、沟通和报告: ...

OCTAVE: 营运关键威胁、资产和脆弱性评估

着重操作风险

- 自我指导式: 业务+IT团队组成小型团队 - 举办研讨会 — 灵活: 定制化解决方法
- 流程: 建立基于资产的威胁配置文件 - 识别基础架构漏洞 - 制定安全策略和计划
- 操作风险导向 + 在业务中解决IT问题
- 劣: 太复杂、不允许风险数学建模

信息风险要素分析FAIR

- 目的: 业务和IT能够使用通用语言沟通风险
- 组成: 信息风险分类法, 信息风险术语的标准命名、数据收集标准框架、风险度量标准和分析模型
- 优: 数学建模-使用美元估计损失、颗粒度更细的风险分类
- 劣: 难用、缺少参考文档

威胁代理风险评估TARA

by Intel

- 目的: 从大量安全攻击中提炼最关键的威胁 - 防御每个风险是昂贵且不现实的
- 组成: 预测框架-优先级排序 by intel威胁代理库 + 通用暴露库 + intel方法和目标库
- 劣: 比起资产、更关注威胁; 未考虑威胁影响; 定性分析